

## Lab 3: Architectural Justification

### Patient Health Record Consent Management System

Problem Statement #13 | Healthcare & Telemedicine

---

#### Architecture Selection

We chose **Layered Architecture** for the Patient Health Record Consent Management System.

#### Two Reasons for Architectural Choice

**1. Natural Layer Alignment with System Requirements:** The system's functional requirements map directly and cleanly onto three distinct layers. The Presentation Layer handles the Patient Portal UI (FR-005: real-time consent dashboard). The Business Layer encapsulates all consent logic — granting, revoking, credential verification, and token management (FR-001 to FR-004). The Data Layer manages encrypted health records and the append-only audit trail (NFR-001, NFR-002). This separation makes each component's responsibility unambiguous, reduces cross-component coupling, and simplifies future maintenance.

**2. Consistent Enforcement of Access Control Policies:** A layered architecture enforces a single, mandatory path through the Business Layer for every request originating from the Presentation Layer. This means role-based access control (RBAC) and credential verification (FR-003) are applied uniformly on every API call before any data is accessed, preventing any component from bypassing security checks — a critical requirement given the sensitivity of patient health records.

#### Security Advantage

The Layered Architecture creates a **single, inescapable security gateway** at the Business Layer (Consent Manager). Every request — whether to grant, revoke, or access a record — must pass through this layer, where AES-256 encryption validation, TLS 1.3 enforcement, RBAC verification, and doctor credential checks (NFR-002, FR-003) are applied before any data layer interaction. No component in the Presentation Layer can directly reach the Patient Record Store, eliminating the risk of privilege escalation or unauthorised direct data access. The append-only audit trail (NFR-001) is also written from this central layer, ensuring no audit event can be omitted.

#### Performance Benefit

The Layered Architecture enables the **Audit & Scheduler Service** to operate as an independent, asynchronous background component. Audit writes and consent expiry countdowns (FR-004: auto-expiry within 1 minute; FR-005: dashboard update within 10 seconds) execute without blocking or degrading the patient-facing consent flow. This separation of the synchronous consent path from the asynchronous audit/expiry path ensures that peak load on the scheduler does not introduce latency for patients actively managing consents, directly satisfying the performance acceptance criteria defined in NFR-001.

### Lab 3: UML Component Diagram

Patient Health Record Consent Management System — Layered Architecture

